TITLE OF THE PROJECT

Replacing Legacy VPN with Cloud-Native Zero Trust Network Access (ZTNA) using Zscaler to Reduce Attack Surface and Prevent Lateral Movement

TEAM ID: SWTID-2026-9763

TEAM SIZE:5

LIST OF TEAM MEMBERS:

S.NO	NAME	COLLEGE	CONTACT
1	ROMANIYAN JOHN.J	PPG COLLEGE OF ARTS AND SCIENCE	2328f0022.cas@ppg.edu.in
2	KANAGARAJ.V	PPG COLLEGE OF ARTS AND SCIENCE	2328f0014.cas@ppg.edu.in
3	HEMASHREE.A	PPG COLLEGE OF ARTS AND SCIENCE	2328f0012.cas@ppg.edu.in
4	ABIRAMI.T	PPG COLLEGE OF ARTS AND SCIENCE	2328f0002.cas@ppg.edu.in
5	DINESH KUMAR.S	PPG COLLEGE OF ARTS AND SCIENCE	2328f0010.cas@ppg.edu.in

STAGE 1

LIST OF VULNERABILITY TABLE :

S.NO	CATEGORY NAME	VULNERABILITY NAME	CWE/CVE - NO
1	Broken access control	Incorrect default permissions	CWE-276

REPORT

Vulnerability Name:Incorrect Default permissions

CWE/CVE : 276

OWASP/SANS Category: A01:2025 Broken Access Control

Description: Incorrect default permissions occur when a system, application, or resource is deployed with overly permissive access settings. This can allow unauthorized users to read, modify, or execute files, settings, or functionalities that should be restricted. Attackers can exploit these misconfigurations to gain elevated privileges, access sensitive data, or compromise system integrity.
Business Impact: Exploitation of incorrect default permissions can lead to unauthorized data exposure, privilege escalation, system compromise, and potential regulatory violations. This can cause financial loss, reputational damage, and legal liabilities for the organization.

STAGE 2

OVERVIEW :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to

remediate the vulnerability. Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

TARGET WEBSITE : https://demo.testfire.net/

TARGET IP ADDRESS: 65.61.137.117

OVERVIEW

This project focuses on replacing traditional Virtual Private Network (VPN) architectures with a modern cloud-native **Zero Trust Network Access (ZTNA)** solution using **Zscaler** technology. Traditional VPN systems provide broad network access once a user is authenticated, which can increase the risk of unauthorized access, lateral movement, and cyber attacks.

The proposed system adopts the **Zero Trust security model**, which operates on the principle of **"Never Trust, Always Verify."** Instead of granting full network access, users are provided **application-level access** only after verifying their identity, device posture, and security policies.

The project implements **Zscaler Private Access (ZPA)** to securely connect users to internal applications without exposing the corporate network to the internet. By eliminating direct network connectivity and using encrypted micro-tunnels between users and applications, ZTNA significantly reduces the attack surface.

The system also integrates **identity verification, device posture checks, and continuous monitoring** to ensure secure user access from any location. Suspicious behavior is detected in real time and triggers additional authentication or automatic access restrictions.

This architecture helps organizations protect sensitive data, prevent unauthorized access, and improve overall network security while providing a seamless remote access experience for users.

PROJECT OBJECTIVES

1. Replace legacy VPN infrastructure with **Zero Trust Network Access (ZTNA)**.

2. Implement **secure identity-based access control** using Zscaler.
3. Reduce **attack surface and lateral movement** within internal networks.
4. Enable **secure remote access to applications** without exposing internal servers.
5. Monitor and analyze user behavior to detect suspicious activities.
6. Improve **incident response and security visibility** using centralized logging.

KEY FEATURES OF THE PROPOSED SYSTEM

1. Identity-Based Access Control

Users are authenticated through an Identity Provider before accessing applications. Access is granted based on user role, location, and device security status.

2. Application-Level Segmentation

Instead of network-level access, users can only connect to specific applications they are authorized to use.

3. Encrypted Micro-Tunnels

Secure micro-tunnels are created between the user device and the application using Zscaler's cloud platform.

4. Continuous Security Monitoring

All connections are monitored for anomalies, suspicious activity, and potential threats.

5. Device Posture Verification

The system checks device health such as OS updates, antivirus status, and security policies before granting access.

6. Threat Intelligence Integration

Security logs and threat intelligence feeds are used to detect malicious activity and block suspicious connections.

BENEFITS OF REPLACING LEGACY VPN

Legacy VPN Problems	ZTNA with Zscaler Solution
Broad network access	Application-level access

Legacy VPN Problems	ZTNA with Zscaler Solution
Network exposed to internet	Applications hidden from internet
High risk of lateral movement	Micro-segmentation prevents lateral attacks
Complex infrastructure	Cloud-based architecture
Limited visibility	Centralized logging and analytics

IMPLEMENTATION ARCHITECTURE

The ZTNA architecture includes the following components:

1. **User Device** – Laptop or mobile device accessing applications.
2. **Zscaler Client Connector** – Secure agent installed on user device.
3. **Zscaler Cloud Platform** – Handles authentication and policy enforcement.
4. **App Connector** – Secure gateway deployed in the internal network.
5. **Private Applications** – Internal enterprise applications.

Access Flow:

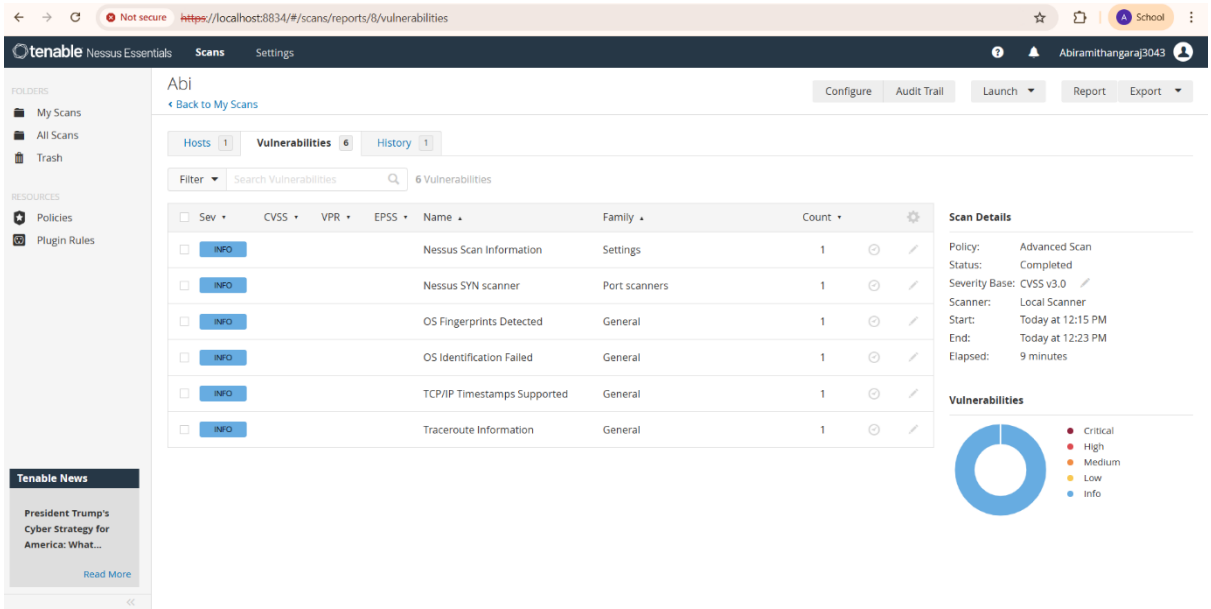
1. User requests access to an internal application.
2. Identity verification through Identity Provider.
3. Device posture validation.
4. Policy evaluation by Zscaler cloud.
5. Encrypted micro-tunnel established between user and application.
6. Continuous monitoring and logging.

SECURITY IMPROVEMENTS

The implementation of ZTNA provides the following security advantages:

- Eliminates traditional VPN attack surface.
- Prevents lateral movement inside the network.
- Protects internal applications from internet exposure.
- Enables granular policy enforcement.
- Provides better monitoring and incident response.

CONCLUSION

This project demonstrates how replacing traditional VPN infrastructure with a **cloud-native Zero Trust Network Access solution using Zscaler** significantly improves network security. By enforcing identity-based access, hiding internal applications, and continuously verifying users and devices, the system reduces cyber risks and enhances secure remote connectivity.

OUTPUT: